PLAN DE RESPUESTA ANTE INCIDENTES

GRC Corporativo

PLAN DE RESPUESTA ANTE INCIDENTES

XYZ S.L. – Gestión Logística Internacional

Elaborado por	Begoña Rodríguez Arteaga
Revisado por	Marta López – Responsable de Seguridad de la Información /Firmado: Marta López / 09/03/2026
Aprobado por	Laura Martínez – Directora General /Firmado: Laura Martínez / 09/03/2026
Versión	1.1
Fecha	09/03/2026
Clasificación	Uso interno – Documento académico con fines formativos
Distribución	Marta López (RSI) · Juan Pérez (IT) · Laura Martínez (DG) · Carlos Ruiz (RPD)
Historial de versiones	v1.0 – 02/03/2026: Elaboración inicial del documento. v1.1 – 09/03/2026: Reestructuración del apartado 4 para enfoque en capacidades de preparación previa (SLA, forense, backups WORM, sandbox de validación). Incorporación de matriz de sustitución de roles, libro de bitácora, estrategia de comunicación en redes sociales y checklist de cadena de custodia.

ÍNDICE

1. **Introducción**
2. **Resumen del Plan**
3. **Escenarios de Riesgo**
   - 3.1 Descripción de escenarios identificados
   - 3.2 Selección del escenario a desarrollar
4. **Desarrollo del Escenario: Ransomware sobre el ERP**
   - 4.1 Contexto, activos implicados y preparación técnica previa
   - 4.2 Señales de detección y umbrales de activación
   - 4.3 Estrategia y capacidades de contención
   - 4.4 Capacidades de erradicación
   - 4.5 Capacidades de recuperación y objetivos de continuidad
   - 4.6 Preparación para la comunicación y obligaciones legales
   - 4.7 Cierre: informe post-incidente y lecciones aprendidas
5. **Equipos de Gestión de Incidentes**
   - 5.1 Estructura organizativa
   - 5.2 Roles y responsabilidades
   - 5.3 Umbrales de escalado y toma de decisiones
6. **Estrategia de Comunicación**
7. **Mejora Continua**
8. **Conclusiones**

Anexo I. Checklist del Plan – Escenario Ransomware ERP

1. Introducción

El presente Plan de Respuesta ante Incidentes (en adelante, PRI) se desarrolla para XYZ S.L. con el objetivo de definir las capacidades, recursos, acuerdos y estructuras organizativas que la empresa debe tener en funcionamiento antes de que se produzca un incidente de seguridad. No es un manual de instrucciones que explica qué botón pulsar durante una crisis: es el documento que acredita que XYZ S.L. está preparada para responder eficazmente cuando esa crisis llegue.

XYZ S.L. presta servicios logísticos internacionales y depende de forma crítica del ERP corporativo alojado en CPD, del entorno Active Directory, de los servicios en la nube y de los dispositivos portátiles usados en teletrabajo. La interrupción de cualquiera de estos activos puede provocar pérdidas operativas, incumplimientos contractuales con clientes y proveedores, y obligaciones legales de notificación en materia de protección de datos. Esta dependencia hace imprescindible no solo saber qué hacer cuando ocurre un incidente, sino haber construido previamente la infraestructura, los contratos, los equipos y los procedimientos que hacen posible una respuesta efectiva.

El PRI complementa el Plan Director de Seguridad y las políticas internas de XYZ S.L. (control de acceso, teletrabajo, correo electrónico, uso de activos), cerrando el ciclo: el Plan Director identifica riesgos y define controles; las políticas establecen normas de comportamiento; el PRI garantiza la capacidad de respuesta cuando los controles fallen. Los tres documentos forman un sistema integrado.

El plan se revisará al menos anualmente o tras cualquier incidente significativo, cambio tecnológico relevante o modificación organizativa que pueda afectar a las capacidades de respuesta definidas.

2. Resumen del Plan

El PRI de XYZ S.L. estructura la capacidad de respuesta de la organización ante incidentes de seguridad de la información en torno a cinco elementos centrales.

Primero, define los escenarios de riesgo prioritarios: los cuatro incidentes más probables e impactantes para la operativa logística de la empresa, con el ransomware sobre el ERP como escenario crítico principal por su capacidad de paralizar simultáneamente disponibilidad, integridad y confidencialidad.

Segundo, detalla las capacidades técnicas y organizativas que deben estar operativas antes del incidente: herramientas de detección, segmentación de red, copias de seguridad inmutables (WORM), contratos de soporte con SLA definidos, kit de respuesta física y canal de comunicación alternativo. Estas capacidades son el núcleo del plan: sin ellas, los procedimientos son inaplicables.

Tercero, establece umbrales objetivos de activación y escalado: criterios técnicos medibles que determinan cuándo una incidencia pasa a ser un incidente gestionado formalmente, cuándo se activa el Comité de Crisis y cuándo procede la notificación a la AEPD.

Cuarto, define la estructura de equipos y roles con responsabilidades concretas, canales de contacto de emergencia y cadena de decisión durante el incidente.

Quinto, incorpora plantillas de comunicación pre-aprobadas, un marco de mejora continua y un Anexo I con la checklist operativa del plan para el escenario de ransomware, que permite verificar que las capacidades están efectivamente disponibles antes del incidente y sirve de guía de actuación durante el mismo.

Objetivos clave del Plan:

Objetivo de recuperación (RTO): el ERP debe estar operativo en un máximo de 24 horas desde la declaración del incidente crítico.

Punto de recuperación (RPO): máxima pérdida de datos aceptable: 4 horas (frecuencia de backup incremental).

Umbral de escalado a Comité de Crisis: afectación del ERP o del CPD durante más de 2 horas consecutivas, o evidencia de exfiltración de datos personales.

Plazo de notificación a la AEPD: 72 horas desde la confirmación de una brecha de datos personales (art. 33 RGPD).

3. Escenarios de Riesgo

Los escenarios se han definido a partir del contexto operativo real de XYZ S.L.: su dependencia del ERP, el uso intensivo del correo electrónico, el teletrabajo con portátiles corporativos y la dependencia de servicios cloud de terceros. No son escenarios genéricos: cada uno responde a una amenaza con alta probabilidad o alto impacto para este negocio concreto.

El profesor Dani señaló en su revisión que los escenarios deberían generalizar el vector de ataque para ampliar su cobertura. Se ha aplicado esa corrección en los escenarios 1 y 2: el vector relevante es la ejecución del malware o el compromiso de credenciales, independientemente del canal de entrada.

3.1 Descripción de escenarios identificados

Nº	Escenario	Activos afectados	Impacto principal	Clasificación
1	Ejecución de malware ransomware con cifrado del ERP corporativo (vector: cualquier medio — correo, USB, recurso de red, URL, nube)	ERP (CPD), servidores, backups accesibles, datos personales de clientes y empleados	Disponibilidad, integridad, confidencialidad. Posible brecha RGPD. Paralización operativa total.	**CRÍTICO**
2	Compromiso de credenciales corporativas (vector: phishing, fuerza bruta, ingeniería social, red WiFi abierta, post-it, MITM u otros)	Active Directory, ERP, servidor de ficheros cloud, correo electrónico	Confidencialidad e integridad. Difícil detección. Escalado de privilegios.	**CRÍTICO**
3	Pérdida o robo de dispositivo corporativo (portátil, tablet o móvil) fuera del entorno controlado	Datos almacenados localmente, credenciales en caché, acceso configurado al ERP	Confidencialidad. Posible brecha RGPD si el dispositivo contiene datos personales.	**ALTO**

4	Indisponibilidad del servicio cloud por incidente en proveedor (ataque, fallo técnico o caída masiva)	Servidor de ficheros cloud, documentación operativa, rutas y clientes	Disponibilidad. Retrasos logísticos e incumplimientos contractuales.	**ALTO**

3.2 Selección del escenario a desarrollar

Se desarrolla en detalle el Escenario 1: ransomware con cifrado del ERP corporativo. Su elección se basa en tres criterios convergentes: es el escenario con mayor impacto potencial sobre la continuidad del negocio (paralización total de la operativa logística), es el que activa más obligaciones simultáneas (técnicas, organizativas, legales y de comunicación), y es el que mejor ilustra la diferencia entre tener un procedimiento de respuesta y haber construido las capacidades necesarias para responder eficazmente.

4. Desarrollo del Escenario: Ransomware sobre el ERP corporativo

4.1 Contexto, activos implicados y preparación técnica previa

El ransomware cifra los archivos del equipo infectado y se propaga lateralmente por la red hacia recursos compartidos y servidores. En XYZ S.L., el vector de entrada puede ser cualquier medio de ejecución de código: adjunto de correo, USB, recurso de red comprometido, enlace a URL maliciosa, fichero descargado desde servicios cloud o desde el servidor de ficheros de un tercero. La gestión del incidente es sustancialmente la misma independientemente del vector; lo relevante es detectarlo y contenerlo.

El ERP corporativo, alojado en el CPD, es el activo más crítico: soporta la gestión de envíos, inventario, rutas, facturación y datos personales de clientes y empleados. Su indisponibilidad paraliza la operativa logística y puede generar pérdidas directas, incumplimientos contractuales y obligaciones de notificación ante la AEPD.

Para que el plan sea ejecutable, deben estar en funcionamiento antes del incidente las siguientes capacidades técnicas:

Capacidad técnica requerida	Estado requerido	Responsable de mantenerla
Solución EDR (Endpoint Detection & Response) con licencias activas en todos los endpoints y servidores del CPD	Activa y con consola de gestión accesible mediante MFA desde red externa	Juan Pérez – IT
Segmentación de red en VLANs: VLAN usuarios, VLAN servidores CPD, VLAN backups (sin acceso directo desde puestos de usuario)	Implementada y documentada en diagrama de red actualizado	Juan Pérez – IT
Copias de seguridad del ERP: backup incremental cada 4h, backup completo diario, almacenado en ubicación secundaria con política WORM (inmutabilidad 30 días)	Verificadas semanalmente mediante prueba de restauración parcial. Registro de pruebas disponible.	Juan Pérez – IT / Marta López – RSI

Servidor de réplica del ERP en CPD secundario o cloud privado, con sincronización mínima cada 4h	Operativo y probado trimestralmente con ejercicio de failover completo	Juan Pérez – IT
Kit de respuesta física disponible en el armario de IT (CPD)	Disco duro externo cifrado para evidencias, portátil aislado de red, cables de red spare, USB con herramientas de análisis forense básico	Juan Pérez – IT
Consola de administración de Active Directory accesible desde red de gestión aislada	Acceso con cuenta privilegiada de emergencia (break-glass) documentada y en sobre sellado en caja fuerte	Marta López – RSI
Contrato de soporte 24×7 con proveedor del ERP (SAP / proveedor aplicable)	SLA: técnico especialista en menos de 4h. Número de soporte de emergencia verificado cada 6 meses	Juan Pérez – IT / Laura Martínez – DG
Kit de evidencias forenses: unidades de almacenamiento externas bloqueadas contra escritura (write-blocker hardware) y software de clonado (FTK Imager en USB) para preservar el estado de los discos afectados antes de cualquier intervención de limpieza. Permite mantener la cadena de custodia para denuncia policial o reclamación al seguro.	Disponible en el armario de IT (CPD). Verificado en el último trimestre.	Juan Pérez – IT
Contrato de retainer con empresa externa de respuesta a incidentes (DFIR): garantiza apoyo especializado en análisis forense y respuesta avanzada si el equipo interno se ve desbordado.	Contrato vigente. Tiempo de respuesta garantizado: < 8h. Contacto de emergencia verificado semestralmente.	Marta López – RSI
Canal de comunicación alternativo al correo corporativo: grupo cifrado en Signal con los cuatro miembros del Comité de Crisis. Los códigos de seguridad de cada contacto han sido verificados presencialmente para evitar ataques de suplantación durante el incidente.	Operativo. Verificación de códigos de seguridad realizada el 10/01/2026. Próxima verificación: 10/07/2026.	Marta López – RSI

4.2 Señales de detección y umbrales de activación

La detección temprana es crítica para limitar el alcance del cifrado. El plan define qué señales activan cada nivel de respuesta y quién toma la decisión en cada caso. Los umbrales son objetivos y medibles, no dependen de la percepción subjetiva de quien atiende el incidente.

Señal observable	Posible causa	Nivel de respuesta	Quién activa
Un usuario reporta que no puede abrir documentos o ve extensiones cambiadas en sus archivos	Ransomware en fase inicial, limitado al puesto	Nivel 1: Incidencia técnica. IT investiga y aísla el equipo en menos de 15 min	Juan Pérez – IT
Alerta del EDR: comportamiento sospechoso de cifrado masivo detectado en un endpoint o servidor	Ransomware activo. Propagación en curso	Nivel 2: Incidente de seguridad. RSI notificada en <30 min. Plan activado formalmente	Marta López – RSI
ERP inaccesible o con errores de escritura/lectura en más del 10% de los registros	Ransomware alcanzó servidores del CPD	Nivel 3: Incidente crítico. Comité de Crisis activado. Dirección informada en <1h	Marta López – RSI + Laura Martínez – DG
ERP caído más de 2 horas consecutivas O evidencia de exfiltración de datos	Impacto operativo grave. Posible brecha RGPD	Nivel 3 + activación de protocolo legal. Evaluación de notificación AEPD en <72h	Marta López + Carlos Ruiz – RPD

Criterio de activación del Comité de Crisis:

El umbral de escalado al Comité de Crisis (Nivel 3) no requiere certeza absoluta: basta con que el EDR confirme propagación activa hacia la VLAN de servidores o con que el ERP lleve más de 2 horas sin servicio. La incertidumbre no es excusa para no escalar: escalar temprano y bajar de nivel es siempre mejor que escalar tarde.

4.3 Estrategia y capacidades de contención

La estrategia de contención tiene un único objetivo: proteger los backups y los sistemas aún no cifrados, especialmente el CPD secundario. Para lograrlo, el plan define qué capacidades técnicas deben existir y qué decisiones se toman según el nivel de afectación detectado.

Capacidades técnicas necesarias para la contención:

- Segmentación de red en VLANs ya implementada (ver 4.1): permite aislar la VLAN de usuarios de la VLAN de servidores con un único cambio de regla en el firewall, ejecutable por IT en menos de 15 minutos desde la consola de gestión.
- Consola de administración de AD accesible desde red de gestión aislada: permite deshabilitar cuentas comprometidas sin necesidad de acceder a la red de usuarios potencialmente afectada.
- EDR con capacidad de aislamiento remoto de endpoints: permite desconectar un equipo de la red corporativa sin necesidad de acceso físico.
- Kit de respuesta física y de evidencias forenses (ver 4.1): el portátil aislado permite conectarse directamente al switch de gestión sin pasar por la red de usuarios. El write-blocker hardware y FTK Imager permiten clonar los discos afectados antes de cualquier formateo, preservando la cadena de custodia necesaria para denuncia policial o reclamación al seguro.

Nivel afectación	Acción de contención	Tiempo objetivo	Responsable
Nivel 1: 1 equipo de usuario	Aislamiento físico o lógico (EDR) del equipo afectado. Deshabilitación de la cuenta de usuario en AD.	< 15 min desde detección	Juan Pérez – IT
Nivel 2: Propagación en curso (varios equipos o un servidor no crítico)	Segmentación de VLAN: corte de tráfico entre VLAN usuarios y VLAN servidores en firewall. Revocación de credenciales con acceso a recursos compartidos.	< 30 min desde confirmación propagación	Juan Pérez – IT + Marta López – RSI
Nivel 3: Afectación al CPD / ERP	Aislamiento completo de la VLAN de servidores. Suspensión temporal del acceso VPN externo. Desconexión manual del servidor de backups si no está ya en VLAN aislada.	< 1 hora desde confirmación afectación ERP	Juan Pérez – IT + Marta López – RSI + aprobación DG

	Activación del servidor de réplica en CPD secundario.		

4.4 Capacidades de erradicación

La erradicación no puede iniciarse hasta que la contención está confirmada: introducir en la red un sistema «limpio» antes de cerrar los vectores activos lo convierte en una nueva víctima. El plan define las capacidades técnicas que hacen posible una erradicación segura.

Capacidades requeridas:

- Entorno Sandbox de validación de backups: antes de volcar cualquier backup al entorno de producción, los datos se restauran en un entorno aislado (sin conectividad de red hacia el CPD ni hacia la VLAN de usuarios) donde se ejecuta un análisis completo con el EDR actualizado y una verificación manual de scripts de inicio y tareas programadas. Solo tras la confirmación de ausencia de malware dormido o mecanismos de persistencia se autoriza el volcado a producción. Este paso es obligatorio aunque exista presión para acelerar la recuperación: un backup infectado que se restaura en producción reinicia el incidente desde cero.
- Acceso a inteligencia de amenazas: el equipo de IT debe disponer de acceso a plataformas de IOC (indicadores de compromiso) para identificar la familia de ransomware, sus mecanismos de persistencia y las herramientas de limpieza disponibles. Se puede usar, entre otras, la base de datos pública de MITRE ATT&CK y el servicio MalwareBazaar.
- Política de reinstalación limpia documentada: XYZ S.L. dispone de imágenes base de los sistemas operativos de los puestos de trabajo y servidores, almacenadas en la VLAN de backups. La reinstalación de un puesto estándar debe realizarse en menos de 2 horas siguiendo el procedimiento documentado de Juan Pérez (IT).
- Contrato con proveedor del ERP (SLA < 4h): la reinstalación del ERP en el servidor limpio requiere intervención del proveedor para validar la integridad de la aplicación. El contrato de soporte 24×7 garantiza disponibilidad del técnico especialista en menos de 4 horas.

- Cadena de custodia de evidencias: antes de cualquier acción de limpieza o reinstalación, el equipo de IT clona los discos afectados mediante write-blocker hardware y FTK Imager (disponibles en el kit forense del CPD). Las imágenes se almacenan en unidad externa cifrada e inventariada. Este paso es irrenunciable: sin evidencias preservadas no es posible ni la denuncia ante las Fuerzas y Cuerpos de Seguridad del Estado ni la reclamación al seguro.
- Contrato de retainer con empresa externa de respuesta a incidentes (DFIR): si el análisis forense supera la capacidad interna del equipo de IT — por la complejidad del ransomware, por volumen de sistemas afectados o por necesidad de testimonio pericial —, se activa el retainer contratado (ver 4.1). El responsable de la activación es Marta López (RSI) con aprobación de la Dirección General.

4.5 Capacidades de recuperación y objetivos de continuidad

El plan define los objetivos de recuperación (RTO y RPO) y las capacidades técnicas que permiten alcanzarlos. Sin esas capacidades preinstaladas, los objetivos son declaraciones vacías.

Objetivo	Valor definido	Capacidad técnica que lo hace posible
RTO (Recovery Time Objective) Tiempo máximo de indisponibilidad del ERP	24 horas desde declaración de incidente crítico (Nivel 3), conforme al BIA v2. Gracias al servidor de réplica local, el objetivo práctico es ≤ 4h de volcado + 2h de validación, dejando margen amplio respecto al RTO contractual de 24h.	Servidor de réplica del ERP en CPD secundario con sincronización ≤ 4h. Contrato SLA < 4h con proveedor ERP. Proceso de failover documentado y probado el 15/01/2026 con resultado: ÉXITO (tiempo real de recuperación: 3h 45min).
RPO (Recovery Point Objective) Máxima pérdida de datos aceptable	4 horas (máximo desfase entre el último backup incremental válido y el momento del incidente), conforme al BIA v2.	Backup incremental cada 4h con política WORM (inmutabilidad 30 días). Almacenado en VLAN aislada no accesible desde puestos de usuario. Verificado semanalmente mediante prueba de restauración parcial. Última prueba: 03/03/2026. Resultado: ÉXITO.

Integridad de los datos restaurados	Validación funcional completa antes de reabrir acceso a usuarios	Checklist de validación post-restauración (ver Anexo I). Responsable: Juan Pérez + proveedor ERP. Tiempo estimado: 2 horas.
Restablecimiento progresivo del servicio	Acceso habilitado por grupos funcionales, comenzando por operaciones logísticas críticas	Procedimiento de reactivación por fases documentado. Monitorización reforzada (EDR + logs de acceso) durante 72h post-recuperación.

Requisito de validación previa:

La diferencia entre tener un RTO de 24h y poder cumplirlo está en haber probado previamente el proceso de failover. Si el servidor de réplica nunca se ha probado en condiciones reales, el RTO de 24h es un deseo, no un compromiso. El plan exige que los ejercicios de failover queden documentados con fecha, resultado y firmados por el RSI.

4.6 Preparación para la comunicación y obligaciones legales

Una de las lecciones más consistentes en la gestión de incidentes reales es que la comunicación improvisada durante la crisis causa tanto daño como el propio incidente. El plan define qué debe estar preparado antes para que, cuando llegue el momento, solo haya que completar y enviar.

Plantillas pre-aprobadas disponibles antes del incidente:

- Plantilla de comunicación interna a empleados: informa del incidente, instrucciones de actuación (desconectar equipos, no usar el correo corporativo hasta nueva indicación, usar el canal alternativo en Signal) y persona de contacto. Aprobada por Laura Martínez (DG) y Marta López (RSI).
- Plantilla de comunicación a clientes afectados (operativa logística interrumpida): redactada en tono transparente y profesional. Incluye impacto estimado, medidas adoptadas y tiempo estimado de restablecimiento. Aprobada por Laura Martínez (DG) y revisada por Carlos Ruiz (RPD).
- Plantilla de notificación a la AEPD (brecha de datos personales, art. 33 RGPD): incluye campos predefinidos para descripción del incidente, categorías de datos afectados,

número estimado de interesados y medidas adoptadas. Revisada por Carlos Ruiz (RPD). Disponible en el sistema de gestión de cumplimiento.

- Plantilla de comunicación a interesados afectados (art. 34 RGPD, si aplica): para los casos en que el riesgo para los derechos de las personas sea elevado y proceda la comunicación directa.

Otros elementos de preparación previa:

- Listado de contactos de emergencia verificado y actualizado trimestralmente: nombre, cargo, teléfono personal y correo alternativo de Marta López, Juan Pérez, Laura Martínez, Carlos Ruiz, proveedor ERP (soporte 24×7) y asesor legal externo. Disponible en formato impreso en la caja fuerte del CPD y en el canal cifrado de Signal.
- Canal de comunicación alternativo (Signal): ante la caída del correo corporativo, el equipo de gestión usa el grupo de Signal configurado previamente. Los códigos de seguridad de cada contacto han sido verificados presencialmente el 10/01/2026 para prevenir ataques de suplantación de identidad durante el caos del incidente. Próxima verificación programada: 10/07/2026.
- Criterio de notificación a la AEPD: si el análisis forense concluye que ha podido existir acceso o exfiltración de datos personales, Carlos Ruiz (RPD) inicia el proceso de notificación dentro de las primeras 24h desde la confirmación, para cumplir el plazo de 72h del art. 33 RGPD. Si no hay evidencia de brecha, se documenta el análisis y la decisión de no notificar, garantizando trazabilidad.

4.7 Cierre: informe post-incidente y marco de lecciones aprendidas

El cierre del incidente no se declara cuando el ERP vuelve a funcionar: se declara cuando el entorno está estabilizado, la documentación está completa y se ha iniciado el análisis post-incidente. La recuperación técnica es condición necesaria pero no suficiente.

Contenido mínimo del informe de cierre (elaborado por Marta López – RSI en un plazo máximo de 5 días hábiles desde la recuperación):

- Cronología del incidente: hora de detección, hora de activación del plan, hitos de contención, erradicación y recuperación.
- Tiempo real de indisponibilidad del ERP vs. RTO definido. Si el RTO no se cumplió, análisis de las causas.
- Alcance real del incidente: equipos afectados, datos comprometidos o en riesgo, impacto económico estimado.
- Evaluación de cada capacidad del plan: ¿funcionó según lo previsto? ¿Qué falló? ¿Qué debe corregirse?
- Acciones correctivas con responsable y plazo: actualizaciones de configuración, revisión de contratos, mejoras en segmentación de red, ajustes en frecuencia de backups, formación adicional.
- Decisión sobre notificación a la AEPD y trazabilidad del análisis realizado.

Nota sobre la secuencia correcta:

El análisis post-incidente (post-activity review) precede a las lecciones aprendidas: primero se evalúa objetivamente qué ocurrió y cómo respondió el plan (post-activity), y después se extraen las conclusiones estructurales que deben incorporarse al plan, las políticas y el sistema de gestión (lessons learned). Esta secuencia garantiza que las lecciones se basan en hechos analizados y no en percepciones inmediatas durante la crisis.

5. Equipos de Gestión de Incidentes

5.1 Estructura organizativa

XYZ S.L. adopta un modelo de activación escalable que no requiere un equipo dedicado permanente. La estructura se activa en función del nivel de gravedad del incidente y garantiza que cada nivel cuenta con los recursos necesarios para responder.

Nivel incidente	Equipo activado	Autoridad de decisión
Nivel 1 – Incidencia técnica	Juan Pérez (IT)	Juan Pérez – IT
Nivel 2 – Incidente de seguridad	Juan Pérez (IT) + Marta López (RSI)	Marta López – RSI
Nivel 3 – Incidente crítico (Comité de Crisis)	Juan Pérez + Marta López + Laura Martínez (DG) + Carlos Ruiz (RPD)	Laura Martínez – DG

5.2 Roles y responsabilidades

Rol	Persona	Responsabilidades clave durante un incidente
Responsable de Seguridad de la Información (RSI) – Coordinador del incidente	Marta López	Declaración formal del incidente. Activación del plan. Coordinación técnica y organizativa. Supervisión de la documentación y del informe de cierre. Interlocución con Carlos Ruiz (RPD) para evaluación legal.
Responsable de IT	Juan Pérez	Ejecución técnica: aislamiento, análisis, erradicación y recuperación. Gestión del kit de respuesta y de las consolas de administración. Interlocución con el proveedor del ERP. Registro de todas las acciones técnicas con marca de tiempo.
Directora General	Laura Martínez	Validación de decisiones estratégicas en Nivel 3: activación de continuidad de negocio, autorización de comunicaciones externas, priorización de recursos extraordinarios. Portavoz institucional si se requiere.

Responsable de Protección de Datos (RPD)	Carlos Ruiz	Evaluación del impacto en datos personales. Decisión sobre notificación a la AEPD y comunicación a interesados. Garantía de trazabilidad legal del proceso.
RRHH (si aplica)	–	Intervención en casos de incumplimiento de políticas internas por parte de empleados, conforme al régimen disciplinario vigente.

Sustitución de roles:

Matriz de sustitución: el plan debe funcionar aunque el responsable principal no esté disponible. En ausencia de Marta López (RSI), la autoridad de escalado y activación del plan recae automáticamente en Juan Pérez (IT), quien asume las funciones de coordinación hasta que el RSI esté operativo. En ausencia simultánea de ambos, la activación corresponde a Laura Martínez (DG). Esta cadena garantiza que ninguna ausencia —vacaciones, baja, desconexión— detiene la respuesta.

5.3 Umbrales de escalado y toma de decisiones

Los umbrales de escalado son objetivos y medibles. No dependen del criterio del técnico que detecta el incidente, sino de condiciones concretas que se evalúan en el momento de la detección.

Libro de Bitácora del Incidente (Incident Log):

Toda decisión crítica adoptada durante el incidente —cambios de nivel de escalado, autorizaciones de aislamiento, activación del Comité de Crisis, decisiones de comunicación— debe quedar registrada con marca de tiempo por el Secretario del Comité de Crisis (rol asumido por Carlos Ruiz – RPD en incidentes de Nivel 3). El registro se realiza en el formulario de Incident Log disponible en el kit de respuesta física del CPD. Este libro es el soporte documental para la reconstrucción posterior de los hechos, la defensa ante reclamaciones de seguro y la demostración de diligencia ante la AEPD o cualquier autoridad supervisora.

Condición técnica objetiva	Nivel resultante	Acción inmediata
Un único equipo de usuario afectado, sin propagación confirmada	Nivel 1	IT investiga y aísla. RSI informada pero no activa el plan formalmente.
EDR confirma propagación a más de un equipo O un servidor no crítico afectado	Nivel 2	RSI activa el plan. Incidente registrado formalmente. IT en modo respuesta activa.
ERP afectado O CPD con síntomas O más de 2h de indisponibilidad del ERP	Nivel 3	Comité de Crisis activado. DG informada. Evaluación legal iniciada.
Evidencia de exfiltración de datos personales (logs de transferencia anómalos, nota de extorsión con muestras de datos)	Nivel 3 + protocolo RGPD	Carlos Ruiz inicia proceso de notificación AEPD. Plazo máximo: 72h desde confirmación.

6. Estrategia de Comunicación

La estrategia de comunicación del PRI no define mensajes durante el incidente: define qué debe estar preparado antes para que la comunicación durante el incidente sea rápida, coherente y no genere daño adicional.

Destinatario	Canal	Plantilla pre-aprobada	Responsable de emisión	Cuándo
Dirección General	Signal (canal alternativo) + presencial	No requiere plantilla – briefing oral estructurado	Marta López – RSI	Al activar Nivel 2 o Nivel 3
Equipo de IT	Signal + teléfono personal	Instrucciones de actuación técnica inmediata	Marta López – RSI	Al activar cualquier nivel
Empleados afectados	Signal + comunicado interno impreso	Plantilla interna pre-aprobada (disponible en carpeta de seguridad)	Laura Martínez – DG	Cuando el correo corporativo esté inaccesible o proceda comunicación general
Clientes (si hay impacto en servicio)	Correo alternativo + teléfono	Plantilla de cliente pre-aprobada (revisada legalmente)	Laura Martínez – DG	Solo cuando el impacto en el servicio esté confirmado
AEPD (si hay brecha de datos)	Portal web AEPD	Plantilla notificación art. 33 RGPD (pre-cumplimentada)	Carlos Ruiz – RPD	Antes de 72h desde confirmación de brecha
Interesados (si riesgo elevado)	Correo o carta certificada	Plantilla art. 34 RGPD	Carlos Ruiz – RPD	Conforme a evaluación de riesgo post-análisis

Reglas de control de la comunicación:

- Ningún empleado está autorizado a realizar declaraciones públicas sobre el incidente sin aprobación expresa de la Dirección General.

- Guía de 'No comentario' para empleados: ante preguntas de prensa, clientes o contactos externos, la respuesta estándar es: 'XYZ S.L. está gestionando activamente la situación y emitirá comunicación oficial en breve. Por favor, diríjase al canal oficial de comunicación.' Esta guía está disponible en la plantilla interna pre-aprobada.
- Monitorización de redes sociales: desde el momento de activación del Nivel 3, Marta López (RSI) o la persona designada realiza búsquedas periódicas (cada 2 horas) en redes sociales y foros relevantes para detectar filtraciones externas del incidente antes de la comunicación oficial. Si se detecta filtración, se activa de inmediato la comunicación proactiva a clientes para evitar que la narrativa la controlen terceros.
- La información se transmite solo cuando ha sido verificada. No se difunden hipótesis ni estimaciones sin contrastar.
- En Nivel 3, Laura Martínez actúa como portavoz institucional único para comunicaciones externas.
- Todos los comunicados emitidos quedan archivados con fecha y hora como parte de la documentación del incidente.

7. Mejora Continua

La mejora continua del PRI se articula en tres niveles: el aprendizaje post-incidente, la revisión periódica del plan y la integración con el sistema de gestión de la seguridad de XYZ S.L.

Actividad	Frecuencia	Responsable	Resultado esperado
Análisis post-incidente (post-activity review) tras cualquier incidente de Nivel 2 o superior	Inmediato al cierre (plazo máx. 5 días hábiles)	Marta López – RSI	Informe de cierre con evaluación de eficacia del plan y acciones correctivas
Revisión anual del PRI completo	Anual (y tras cambios relevantes en tecnología, organización o normativa)	Marta López – RSI + Juan Pérez – IT	Versión actualizada del plan con control de cambios
Ejercicio de failover del ERP (prueba de recuperación real)	Trimestral	Juan Pérez – IT	Registro firmado: fecha, tiempo de recuperación real vs. RTO, incidencias
Verificación del kit de respuesta física y del canal alternativo (Signal)	Mensual	Juan Pérez – IT	Confirmación de disponibilidad y funcionamiento de todos los elementos
Verificación del SLA del proveedor ERP y del listado de contactos de emergencia	Semestral	Marta López – RSI	Listado actualizado, confirmación de vigencia del contrato de soporte 24×7
Simulacro de comunicación de crisis (tabletop exercise)	Anual	Laura Martínez – DG + Marta López – RSI	Evaluación del tiempo de reacción y de la coherencia de la comunicación

Sobre la relación entre el PRI y el Plan Director de Seguridad:

El Plan Director de Seguridad es un proyecto con inicio y fin: define una hoja de ruta de mejoras en un momento dado. El PRI es un documento operativo que debe actualizarse de forma continua. Las lecciones aprendidas de los incidentes pueden generar tanto actualizaciones del PRI (ajustes en capacidades, umbrales o plantillas) como nuevas

iniciativas en el Plan Director (proyectos de mejora de infraestructura o formación). Ambos documentos se complementan pero no son equivalentes.

8. Conclusiones

El Plan de Respuesta ante Incidentes elaborado para XYZ S.L. no es un manual de instrucciones para gestionar una crisis: es la demostración documentada de que la organización ha construido las capacidades necesarias para responder eficazmente cuando esa crisis llegue.

La distinción es fundamental. Un procedimiento de respuesta dice qué hacer cuando el ransomware ya está cifrando los servidores. Un plan de respuesta dice qué debe haber hecho XYZ S.L. antes de ese momento: qué servidor de réplica debe existir y haberse probado, qué contrato de soporte debe estar firmado, qué backups deben estar en VLAN aislada con política WORM, qué plantillas de comunicación deben estar pre-aprobadas por legal y qué canal alternativo debe funcionar cuando el correo corporativo caiga. Sin esas capacidades previas, los procedimientos son papel.

El escenario desarrollado —ransomware sobre el ERP corporativo— ilustra con precisión esta diferencia. El plan no dice «restaurar el backup»: dice «el RTO de 24h es alcanzable porque existe un servidor de réplica probado trimestralmente, un backup incremental cada 4 horas con inmutabilidad de 30 días y un contrato de soporte con el proveedor del ERP que garantiza técnico especialista en menos de 4 horas».

El valor de este plan se mide en la reducción del tiempo de indisponibilidad del ERP, en el cumplimiento del plazo de 72 horas para la notificación a la AEPD y en la capacidad de comunicar a clientes y empleados sin improvisación ni contradicciones. Esos resultados solo son posibles si las capacidades descritas están efectivamente implementadas, verificadas y mantenidas.

Anexo I. Checklist del Plan – Escenario Ransomware ERP

Esta checklist no es una lista de pasos para ejecutar durante el incidente. Es el instrumento de verificación que permite comprobar, antes del incidente, que todas las capacidades definidas en el plan están efectivamente disponibles. Debe revisarse mensualmente por el RSI y firmarse. Cualquier ítem marcado como no disponible genera automáticamente una acción correctiva con plazo.

> Uso de esta checklist: antes del incidente → verificación de capacidades. Durante el incidente → referencia rápida de qué herramientas y contactos están disponibles. Después del incidente → evaluación de qué capacidades funcionaron y cuáles fallaron.

A. Capacidades técnicas de detección

- ☐ Licencias EDR activas en todos los endpoints y servidores del CPD. Consola accesible con MFA desde red externa.
- ☐ Alertas de comportamiento de cifrado masivo configuradas y testeadas en el EDR.
- ☐ Logs de acceso del Active Directory habilitados con retención mínima de 90 días.
- ☐ Sistema de monitorización de tráfico entre VLANs operativo (detección de movimiento lateral).

B. Capacidades de contención

- ☐ Segmentación de red en VLANs implementada y documentada: VLAN usuarios / VLAN servidores CPD / VLAN backups.
- ☐ Acceso a la consola del firewall desde red de gestión aislada. Tiempo de cambio de regla verificado: < 15 min.
- ☐ Consola de AD accesible desde red de gestión. Cuenta break-glass documentada y en sobre sellado en caja fuerte.
- ☐ Capacidad de aislamiento remoto de endpoints mediante EDR verificada en el último trimestre.

- ☐ Kit de respuesta física disponible en armario de IT: disco externo cifrado, portátil aislado, cables, USB con herramientas forenses.
- ☐ Kit de evidencias forenses completo: write-blocker hardware, FTK Imager en USB, unidades externas cifradas inventariadas. Verificado: 03/03/2026.
- ☐ Formularios de Cadena de Custodia impresos disponibles en el kit: registro físico de cada evidencia (disco, memoria, dispositivo) con campos de identificación, fecha/hora de recogida, responsable y hash de verificación. Sin este formulario, el kit forense está incompleto a efectos legales.

C. Capacidades de recuperación

- ☐ Backup incremental del ERP ejecutándose cada 4h. Último backup verificado: 03/03/2026. Resultado: ÉXITO.
- ☐ Política WORM (inmutabilidad 30 días) activa en el repositorio de backups. Almacenado en VLAN aislada.
- ☐ Prueba de restauración parcial realizada en la última semana. Fecha: 03/03/2026. Resultado: ÉXITO (volumen restaurado: 120 GB en 47 min).
- ☐ Servidor de réplica del ERP operativo en CPD secundario. Último ejercicio de failover completo: 15/01/2026. Resultado: ÉXITO. Tiempo real de recuperación: 3h 45min (RTO objetivo: 24h / objetivo práctico: ≤ 6h). Próximo ejercicio programado: 15/04/2026.
- ☐ Contrato de soporte 24×7 con proveedor ERP vigente hasta 31/12/2026. Número de soporte de emergencia verificado: 15/01/2026.

D. Comunicación y preparación legal

- ☐ Plantilla de comunicación interna a empleados disponible en la carpeta de seguridad. Última aprobación por DG: 02/01/2026.
- ☐ Plantilla de comunicación a clientes disponible. Última revisión legal: 02/01/2026.
- ☐ Plantilla de notificación AEPD (art. 33 RGPD) disponible. Revisada por Carlos Ruiz (RPD): 02/01/2026.

- ☐ Canal de comunicación alternativo (Signal) operativo. Códigos de seguridad verificados presencialmente el 10/01/2026 con: Marta López, Juan Pérez, Laura Martínez, Carlos Ruiz. Próxima verificación: 10/07/2026.
- ☐ Listado de contactos de emergencia actualizado: proveedor ERP (soporte 24×7), empresa DFIR (retainer), asesor legal externo, AEPD. Última actualización: 15/01/2026.

E. Validación general del plan

- ☐ Todos los ítems anteriores están marcados como disponibles O tienen acción correctiva con plazo asignado.
- ☐ El plan ha sido revisado en los últimos 12 meses o tras el último incidente significativo.
- ☐ Los roles y datos de contacto de los miembros del equipo de respuesta están actualizados.

Campo	Detalle
Revisado por	Marta López – Responsable de Seguridad de la Información
Fecha de verificación	03/03/2026
Ítems no disponibles (número)	0 – Todos los ítems verificados como disponibles
Acciones correctivas abiertas	Ninguna
Firma RSI	/Firmado digitalmente: Marta López – RSI / 03/03/2026